

- Software Requirements Specification (SRS)
 - 1. Introduction
 - 1.1 Purpose
 - 1.2 Scope
 - 1.3 Definitions, Acronyms & Abbreviations
 - 1.4 References
 - 2. Overall Description
 - 2.1 Product Perspective
 - 2.2 High-Level Architecture
 - 2.3 User Classes and Characteristics
 - 2.4 Operating Environment
 - 2.5 Design Constraints
 - 2.6 Assumptions and Dependencies
 - 3. System Features (Functional Requirements)
 - 3.1 Authentication & Session Management
 - 3.2 Role-Based Access Control (RBAC)
 - 3.3 User & Profile Management
 - 3.4 Client Management
 - 3.5 Vessel Registry
 - 3.6 Job Lifecycle
 - 3.7 Surveys
 - 3.8 Checklists & Templates
 - 3.9 Certificates
 - 3.10 Documents & Evidence
 - 3.11 Non-Conformities
 - 3.12 Approvals & Change Requests
 - 3.13 TOCA (Transfer of Class)
 - 3.14 Payments
 - 3.15 Notifications
 - 3.16 Reports & Dashboards
 - 3.17 Search
 - 3.18 Compliance (GDPR-style)
 - 3.19 Public Surface
 - 3.20 Customer Support & Activity / Incidents
 - 3.21 Background Jobs
 - 3.22 System Operations
 - 4. External Interface Requirements

- 4.1 REST API
- 4.2 OpenAPI / Swagger
- 4.3 File Storage
- 4.4 Email
- 4.5 Push Notifications
- 4.6 Database
- 5. Data Requirements
 - 5.1 Core Entities (representative — see src/models/ for the full set)
 - 5.2 Data Retention & Audit
 - 5.3 Backups
- 6. Error Handling & Logging
- 7. Non-Functional Requirements
 - 7.1 Performance
 - 7.2 Availability & Reliability
 - 7.3 Security
 - 7.4 Compliance
 - 7.5 Maintainability
 - 7.6 Portability
 - 7.7 Internationalisation
 - 7.8 Observability
 - 7.9 Scalability
- 8. Standard API Response Shape
- 9. Environment Configuration (must-have variables)
- 10. Acceptance Criteria (per major capability)
- 11. Open Items / Future Work

Software Requirements Specification (SRS)

System Name: GR-Class — Marine Certification & Operations Backend **Version:** 1.0

Audience: Engineering, QA, DevOps, Security, Integration partners **Last Updated:** April 2026

Companion docs: [PRD.md](#) (the product / business view), [MODULES_GUIDE.md](#) (per-module access reference).

1. Introduction

1.1 Purpose

This document specifies the software requirements — functional and non-functional — for the GR-Class backend. It is the technical contract between product and engineering, and the basis for QA acceptance.

1.2 Scope

The system is a **Node.js + Express + Sequelize/MySQL** REST API serving a web client, a surveyor field UI, and a public verification surface. It manages the full marine certification workflow: clients, vessels, jobs, surveys, checklists, certificates, payments, support, and compliance.

1.3 Definitions, Acronyms & Abbreviations

Term	Meaning
RBAC	Role-Based Access Control
JWT	JSON Web Token
S3	AWS Simple Storage Service
FCM	Firebase Cloud Messaging
NC	Non-Conformity
TOCA	Transfer of Class
CA	Certificate Authority
SES	AWS Simple Email Service
SLA	Service-Level Agreement
RPO/RTO	Recovery Point / Time Objective

1.4 References

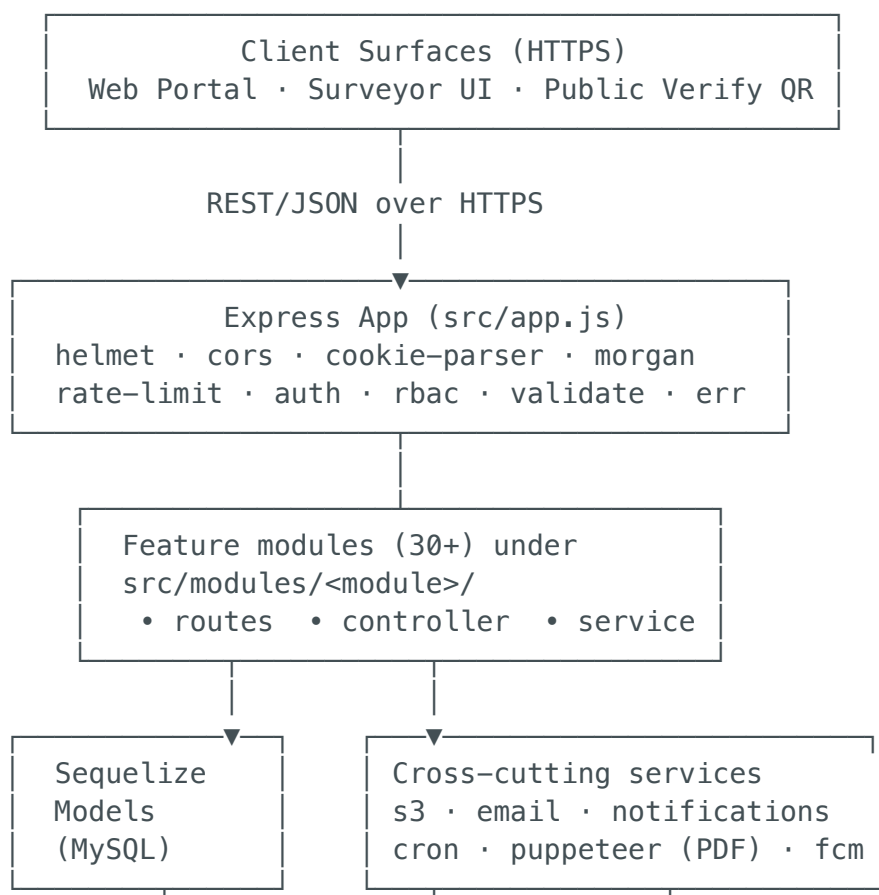
- **PRD.md** — Product Requirements Document
 - **MODULES_GUIDE.md** — Module purpose & access matrix
 - **RBAC_ACCESS_GUIDE.md** — Existing RBAC reference (legacy, partially superseded by **MODULES_GUIDE.md**)
 - **docs/api/** — Generated OpenAPI / Swagger artifacts
 - **README.md** — Setup & dev guide
-

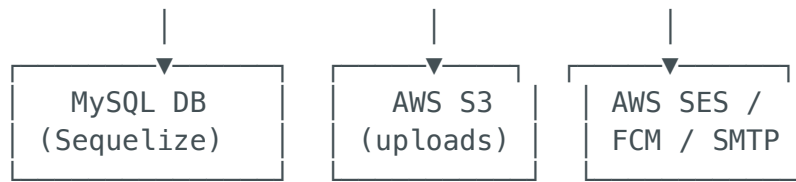
2. Overall Description

2.1 Product Perspective

GR-Class is a **single backend monolith** organized as feature modules under **src/modules/<module>**. Each module owns its routes, controllers, and services. Cross-cutting concerns (auth, RBAC, validation, errors, S3, email, cron, notifications) live as middlewares and services.

2.2 High-Level Architecture





2.3 User Classes and Characteristics

Class	Authenticated	Notes
ADMIN, GM, TM, TO	Yes	Internal staff. Cookies + JWT.
SURVEYOR	Yes	Field user; mobile UA expected.
CLIENT	Yes	External org user. Row-scoped to own data.
PUBLIC	No	Verification & marketing only. Optional rate-limited.

2.4 Operating Environment

- **Runtime:** Node.js (LTS), single Express process; horizontally scalable behind a load balancer.
- **Database:** MySQL / MariaDB via Sequelize ORM.
- **Object storage:** AWS S3 (pre-signed URLs for upload/download).
- **Email:** AWS SES (preferred) and / or SMTP via Nodemailer.
- **Push:** Firebase Cloud Messaging (FCM) for mobile push.
- **Cache (optional):** Redis (used where configured).
- **PDF generation:** Puppeteer (headless Chromium) for certificate rendering.
- **Scheduling:** `node-cron` for background jobs.

2.5 Design Constraints

- ECMAScript modules ("`type`": "`module`" in `package.json`).
- All routes prefixed under `/api/v1`.
- All inbound JSON body validation via **Joi** before reaching controllers.
- All write endpoints must declare an explicit role list via `rbac.middleware.js`.

- File uploads **MUST** go through S3 pre-signed URLs (the API never proxies large bodies, except small Multer-handled assets such as profile pictures and signed checklist scans).
- Database migrations are **append-only**; raw schema mutations are not allowed in PRs.

2.6 Assumptions and Dependencies

- An AWS account with S3, SES, and IAM credentials.
- A reachable MySQL instance.
- A Firebase service account JSON for FCM (only required for push).
- Outbound HTTPS to email/Firebase/AWS endpoints.

3. System Features (Functional Requirements)

Each feature points to its module. See [MODULES_GUIDE.md](#) for the full module roster and per-route role matrix.

3.1 Authentication & Session Management

Module: [auth](#)

- **FR-AUTH-01** Users authenticate with email + password; on success the system returns an access token (JWT) and sets an HttpOnly refresh-token cookie.
- **FR-AUTH-02** Tokens carry the user's [id](#), [role](#), and (for clients) [client_id](#).
- **FR-AUTH-03** Login and refresh-token endpoints are rate-limited.
- **FR-AUTH-04** Forgot-password generates a single-use, time-limited reset token sent over email.
- **FR-AUTH-05** Authenticated users may change password (re-verifying current password) and logout (revoking the cookie).
- **FR-AUTH-06** Failed login attempts are logged for audit.

3.2 Role-Based Access Control (RBAC)

Module: `middlewares/rbac.middleware.js`

- **FR-RBAC-01** Six canonical roles: `ADMIN`, `GM`, `TM`, `TO`, `SURVEYOR`, `CLIENT`. `PUBLIC` represents un-authenticated access.
- **FR-RBAC-02** Every protected route declares allowed roles via `authorizeRoles(...)`. Unmatched roles return **HTTP 403**.
- **FR-RBAC-03** Data scoping (clients see only their own jobs / vessels / certificates; surveyors see only their assigned jobs) is enforced in service-layer queries via a `req.dataScope` derived from the user.
- **FR-RBAC-04** `preventSelfApproval` blocks self-approval on sensitive transitions (e.g., a TM finalizing their own work).
- **FR-RBAC-05** RBAC failures emit a structured 403 response with no leakage of underlying record existence.

3.3 User & Profile Management

Module: `users`

- **FR-USER-01** Authenticated users can view and update their own profile (`/users/me`), profile picture, and FCM token.
- **FR-USER-02** ADMIN can list, create, update, and deactivate any user.
- **FR-USER-03** Soft-deactivate is preferred over hard-delete except where compliance requires anonymization.

3.4 Client Management

Module: `clients`

- **FR-CLIENT-01** ADMIN/GM/TM can create and update client organizations.
- **FR-CLIENT-02** Clients can view their own profile documents.
- **FR-CLIENT-03** Hard delete is restricted to ADMIN.

3.5 Vessel Registry

Module: `vessels`

- **FR-VESSEL-01** Vessels are linked to a client and a flag state, identified by IMO number.
- **FR-VESSEL-02** Internal staff (ADMIN/GM/TM/TO) can list and view vessels; SURVEYOR sees vessels of assigned jobs; CLIENT sees only their own.
- **FR-VESSEL-03** Vessel creation/update is restricted to ADMIN/GM/TM.

3.6 Job Lifecycle

Module: **jobs**

- **FR-JOB-01** A job is created by CLIENT (or staff on their behalf) with vessel + certificate type + supporting documents.
- **FR-JOB-02** State machine (high level):

```
draft → submitted → docs_verified → approved → assigned →
authorized → survey_in_progress → submitted_for_review →
reviewed → finalized → certificate_issued
```

Plus side states: **rejected**, **cancelled**, **sent_back**, **escalated**.

- **FR-JOB-03** Each transition is gated by RBAC (see **MODULES_GUIDE.md** → jobs).
- **FR-JOB-04** Every transition writes a **job_history** audit row with actor, timestamp, and remarks.
- **FR-JOB-05** Internal messages (between staff) and external messages (visible to client) are kept on separate channels.
- **FR-JOB-06** Jobs support a priority flag and SLA/escalation hooks.

3.7 Surveys

Module: **surveys**

- **FR-SRV-01** SURVEYOR begins a survey (**POST /surveys/start**) which captures GPS coords and timestamp.
- **FR-SRV-02** Photo / proof uploads are tied to the running survey via pre-signed S3 URLs.
- **FR-SRV-03** Submission (**POST /surveys**) is rejected if mandatory checklist items / proofs are missing.

- **FR-SRV-04** GPS coordinates are validated against the vessel's expected position; outliers raise a violation flag for review.
- **FR-SRV-05** TM/GM may finalize, request rework, or flag the survey.
`preventSelfApproval` applies.
- **FR-SRV-06** A timeline endpoint replays start, photos, GPS pings, and submission events.

3.8 Checklists & Templates

Modules: `checklists`, `templates`

- **FR-CL-01** TM/ADMIN authors checklist templates per vessel-type / certificate-type.
- **FR-CL-02** When a job is created, the right template is materialized to the job's checklist.
- **FR-CL-03** SURVEYOR completes the checklist on-site; a signed scan can be uploaded.
- **FR-CL-04** Certificate PDF templates (separate `templates` module) are managed by ADMIN.

3.9 Certificates

Module: `certificates`

- **FR-CRT-01** TM/GM generates a draft from a finalized job.
- **FR-CRT-02** GM/ADMIN issues and digitally signs the certificate; signed PDF is stored in S3.
- **FR-CRT-03** Each certificate carries a unique number and a QR pointing to the public verify URL.
- **FR-CRT-04** Lifecycle actions: `suspend`, `revoke`, `restore`, `renew`, `reissue`, `bulk-renew` (TM/ADMIN).
- **FR-CRT-05** External certificates (issued elsewhere) can be uploaded for record purposes by ADMIN/GM.
- **FR-CRT-06** Certificate Authorities (`/certificates/authorities`) are managed by ADMIN; readable by GM.
- **FR-CRT-07** Public verification (`GET /public/certificate/verify/:number`) is open and returns live status.

3.10 Documents & Evidence

Module: **documents**

- **FR-DOC-01** Files upload via pre-signed S3 URLs.
- **FR-DOC-02** Documents are attachable to any entity (client, vessel, job, survey, certificate) by **entityType + entityId**.
- **FR-DOC-03** Read access mirrors the entity's RBAC; delete restricted to ADMIN/GM.

3.11 Non-Conformities

Module: **non_conformities**

- **FR-NC-01** SURVEYOR or TO can raise NCs against a job; severity is captured.
- **FR-NC-02** TO/TM closes an NC after corrective evidence is supplied.
- **FR-NC-03** Open NCs block job finalization (rule enforced in service).

3.12 Approvals & Change Requests

Modules: **approvals, change_requests**

- **FR-APR-01** Generic multi-step internal approval workflow (ADMIN/GM/TM).
- **FR-CR-01** Clients can raise change requests post-issue (e.g., correction of a typo); ADMIN/GM approve or reject.

3.13 TOCA (Transfer of Class)

Module: **toca**

- **FR-TOCA-01** TM creates a transfer record (gaining / losing class society).
- **FR-TOCA-02** Status updates require TM/ADMIN.

3.14 Payments

Module: **payments**

- **FR-PAY-01** ADMIN/GM/TM raises invoices against jobs.
- **FR-PAY-02** Marking paid, partial payment, refund, write-off are role-gated (see module guide).
- **FR-PAY-03** CLIENT can view their own invoices and ledger only.
- **FR-PAY-04** Financial summary endpoint produces totals for reporting.

3.15 Notifications

Module: `notifications`, `services/notification.service.js`

- **FR-NOTIF-01** Material events (assignment, status change, certificate issue, expiry approaching) write a row to `notifications` and fan out to email + push if user opted in.
- **FR-NOTIF-02** All authenticated users can list and mark-as-read their own notifications.
- **FR-NOTIF-03** Email templates live under `src/email-templates/`.

3.16 Reports & Dashboards

Modules: `reports`, `dashboard`

- **FR-RPT-01** Reports are restricted to ADMIN/GM/TM.
- **FR-RPT-02** Dashboards return role-aware summaries (clients see only their own pipeline, etc.).

3.17 Search

Module: `search`

- **FR-SRCH-01** Single endpoint searches vessels, jobs, certificates with role-aware data scoping inside the service.

3.18 Compliance (GDPR-style)

Module: `compliance`

- **FR-CMP-01** ADMIN (or owning CLIENT) can export user/client data as a structured payload.
- **FR-CMP-02** ADMIN can anonymize a user/client; PII fields are scrubbed but referential rows persist for audit.

3.19 Public Surface

Modules: `public`, `website`, `contact`, `feedback` (portfolio)

- **FR-PUB-01** Certificate verification, vessel lookup by IMO, marketing videos, static CMS content, public portfolio testimonials, and a contact form are all exposed without authentication.
- **FR-PUB-02** All public POST endpoints (contact form, surveyor application) are rate-limited.

3.20 Customer Support & Activity / Incidents

Modules: `support`, `activity_requests`, `incidents`

- **FR-SUP-01** Authenticated users can open support tickets; ADMIN/GM update status.
- **FR-AR-01** Activity requests: ad-hoc work items between client and staff.
- **FR-INC-01** Incident reporting with status workflow (similar pattern to activity requests).

3.21 Background Jobs

Module: `services/cron.service.js`

- **FR-BG-01** Daily scan for certificates expiring in {30, 60, 90} days; raises notifications.
- **FR-BG-02** SLA evaluator runs on a schedule and emits escalations.
- **FR-BG-03** Failed background tasks are retryable by ADMIN via `system` routes.

3.22 System Operations

Module: `system`

- **FR-SYS-01** Health, readiness, version endpoints available to authenticated users.
 - **FR-SYS-02** Audit logs, metrics, queue retry, force-logout, feature flags, migration status are ADMIN-only.
-

4. External Interface Requirements

4.1 REST API

- All endpoints under `/api/v1/...`.
- Request: JSON body (or `multipart/form-data` for direct uploads of small assets).
- Response: JSON `{ success: boolean, data?: ..., error?: ... }`.
- Auth: `Authorization: Bearer <accessToken>` header **or** HttpOnly cookie for browser clients.
- Errors: standardized via `error.middleware.js` (see § 6).

4.2 OpenAPI / Swagger

- Generated from JSDoc annotations under `src/docs/build-openapi.js`.
- Per-role swagger artifacts in `docs/api-by-role-swagger/`.

4.3 File Storage

- Uploads via `GET /<entity>/get-upload-url` → returns `{ uploadUrl, fileKey }`.
- Client `PUT`s the binary directly to S3 using that URL.
- Read URLs are pre-signed and time-limited.

4.4 Email

- Transactional via Nodemailer (SMTP) or AWS SES.
- Templates in `src/email-templates/` (HTML with simple variable substitution).

4.5 Push Notifications

- FCM via `firebase-admin`. Each user can register an FCM token via `PUT /users/fcm-token`.

4.6 Database

- MySQL via Sequelize. Migrations under `migrations/`. Models under `src/models/`.
- Time zones: timestamps stored as UTC.

5. Data Requirements

5.1 Core Entities (representative — see `src/models/` for the full set)

Entity	Purpose	Key Relations
User	Identity for any role	belongs to <code>Role</code> (legacy) and optionally <code>Client</code>
Role	Lookup of role codes	—
Client	Ship-owner organization	hasMany <code>Vessel</code> , <code>JobRequest</code>
Vessel	Ship under registration	belongsTo <code>Client</code> , <code>Flag</code>
Flag	Flag state authority	—

Entity	Purpose	Key Relations
JobRequest	A single certification engagement	belongsTo Vessel , CertificateType ; hasMany JobHistory , Survey , NonConformity , Document , Message
JobHistory	Audit trail of state transitions	belongsTo JobRequest , User
Survey	A surveyor's on-site report	belongsTo JobRequest , User ; hasMany SurveyPhoto , GpsPing
Checklist / ChecklistTemplate	Field inspection items	—
Certificate	The issued artifact	belongsTo JobRequest , Vessel , CertificateType , CertificateAuthority ; hasMany CertificateHistory
CertificateType	Catalog of certificate types	hasMany RequiredDocument
CertificateAuthority	Issuing authority	hasMany Certificate
Document	Any uploaded file	polymorphic (entityType , entityId)
NonConformity	Deficiency record	belongsTo JobRequest
Approval, ChangeRequest	Workflow records	—
Toca	Transfer of Class	belongsTo Vessel
Payment	Invoice / ledger row	belongsTo JobRequest

Entity	Purpose	Key Relations
Notification	In-app notification	belongsTo User
SupportTicket, Incident, ActivityRequest	Ops tickets	belongsTo User
Feedback, PortfolioFeedback	Client testimonials	belongsTo Client
SiteStaticContent, Video, NewsletterSubscriber	Marketing CMS	—
AuditLog	System-level audit	indexed by userId , entity , action

5.2 Data Retention & Audit

- **Audit logs and JobHistory:** retained for at least **7 years** for regulatory traceability.
- **Anonymization:** scrubs PII fields (name, email, phone, address) but preserves IDs for referential continuity in audit chains.
- **Soft-delete:** preferred over hard-delete for **User**, **Client**, **Vessel**. Hard-delete is ADMIN-only and discouraged.

5.3 Backups

- Daily logical backups of MySQL.
- S3 versioning enabled on the document bucket.

6. Error Handling & Logging

- **Global error middleware** translates thrown errors into:
 - `ApiError(statusCode, message, details?)` → mapped to JSON

- Sequelize validation errors → 400
 - JWT errors → 401
 - RBAC failures → 403
 - Not found → 404
 - Unhandled → 500 (with stack omitted in production)
 - **Logging:** Winston logger (`src/utils/logger.js`) writes:
 - `combined.log` — all info+
 - `error.log` — error level
 - **HTTP access logs:** `morgan` in dev / structured in prod.
-

7. Non-Functional Requirements

7.1 Performance

Metric	Target
Public verify endpoint p95 latency	≤ 500 ms
Authenticated read endpoints p95	≤ 800 ms
Authenticated write endpoints p95	≤ 1200 ms
Survey submission with proof	≤ 3 s end-to-end (server side)
Certificate PDF render (Puppeteer)	≤ 8 s

7.2 Availability & Reliability

- Target uptime: **99.5%** monthly.
- RPO ≤ 24 h (daily backups). RTO ≤ 4 h.
- Background jobs are idempotent.

7.3 Security

- **Transport:** HTTPS only in production.
- **Headers:** `helmet` defaults applied (`Content-Security-Policy`, `X-Frame-Options`, etc.).

- **CORS:** allow-listed origins via env config.
- **Rate limiting:** `express-rate-limit` on login, refresh, forgot-password, public POSTs (contact, surveyor application).
- **Passwords:** bcrypt (cost ≥ 10).
- **JWT:** HS256 with secret rotation support; access token short-lived; refresh token in HttpOnly cookie.
- **Secrets:** read from `.env` (never committed); production secrets in a secrets manager.
- **Input validation:** Joi schemas mandatory on every write route; allow-list parameter parsing.
- **Output sanitization:** never echo back raw user input in error messages without escaping.
- **File uploads:** content-type allow-list, max-size, virus-scan hook (extension point).
- **RBAC:** server-side mandatory; never trust client-only UI gating.
- **Sensitive ops:** revoke / anonymize / sign require ADMIN; `preventSelfApproval` enforced.
- **Audit:** every state-changing call writes an audit row (user, action, entity, before/after).

7.4 Compliance

- Support GDPR-style export (`GET /compliance/export/:id`) and anonymize (`POST /compliance/anonymize/:id`).
- Right-to-be-forgotten implemented as anonymize, not hard-delete (preserves audit integrity).
- Audit log retention: 7 years.

7.5 Maintainability

- Feature-module folder convention: `routes` → `controller` → `service` → `model`.
- No business logic in routes or controllers beyond glue.
- All cross-module logic lives in `src/services/`.
- ESLint / Prettier (project conventions).
- Database changes are migrations, never raw schema edits.

7.6 Portability

- Runs on any Node.js LTS host with MySQL connectivity. Environment is fully configurable via `.env`.

7.7 Internationalisation

- Locale codes supported on certificate templates; UI translation is the frontend's responsibility.

7.8 Observability

- `/system/health/db`, `/system/readiness`, `/system/version` for liveness checks.
- Structured logs with request id.
- Metrics endpoint (ADMIN-only) returns counts of jobs, certs, users, NCs.

7.9 Scalability

- Stateless API processes — scale horizontally behind a load balancer.
- Long jobs (PDF render, bulk renew) should be moved to a worker queue when load justifies (extension point — currently inline).

8. Standard API Response Shape

```
// Success
{
  "success": true,
  "data": { ... },
  "meta": { "page": 1, "limit": 20, "total": 137 } // when paginated
}

// Failure
{
  "success": false,
  "error": {
    "code": "JOB_NOT_FOUND",
    "message": "Job request not found",
    "details": { ... } // optional, for
validation
```

```
}  
}
```

HTTP status codes follow standard semantics: 200/201, 400 validation, 401 unauthenticated, 403 unauthorized, 404 not found, 409 conflict, 422 business-rule rejection, 429 rate-limit, 500 unhandled.

9. Environment Configuration (must-have variables)

```
PORT  
NODE_ENV  
DB_HOST DB_USER DB_PASS DB_NAME  
JWT_SECRET JWT_EXPIRES_IN  
REFRESH_TOKEN_SECRET REFRESH_TOKEN_EXPIRES_IN  
AWS_REGION AWS_ACCESS_KEY_ID AWS_SECRET_ACCESS_KEY  
S3_BUCKET_NAME  
SES_FROM_EMAIL # or SMTP_*  
SMTP_HOST SMTP_PORT SMTP_USER SMTP_PASS  
FCM_SERVICE_ACCOUNT_PATH  
REDIS_URL # optional  
PUBLIC_BASE_URL # used in QR / verify links  
CORS_ORIGINS  
RATE_LIMIT_WINDOW_MS RATE_LIMIT_MAX
```

10. Acceptance Criteria (per major capability)

Area	Acceptance
Auth	Login → refresh → logout cycle works; failed attempts logged; password reset email delivered
RBAC	Every restricted route returns 403 to wrong role; data scope filters visible only own rows
Job lifecycle	Each transition allowed only by configured role; history row written; notifications fired

Area	Acceptance
Survey	GPS captured at start; submission rejected when mandatory items missing; geo-fence violations flagged
Certificate	Draft → issue → sign produces a signed PDF; verify URL returns live status; revoke updates verify response
Compliance	Export returns PII payload; anonymize scrubs PII while preserving FK integrity
Public verify	Anonymous request returns valid/invalid + issuance & status info; rate-limited
Reports	Role-restricted; counts match underlying queries
Notifications	Trigger events produce DB rows + email + (when token present) push

11. Open Items / Future Work

- Worker queue for heavy operations (PDF, bulk renew, notification fan-out).
- Real payment gateway integration.
- AI anomaly detection on surveys / vessels (placeholders today).
- Real-time socket channel for client ↔ surveyor messaging.
- Mobile offline / sync (deferred from v1.0).

End of SRS. See [MODULES_GUIDE.md](#) for the complete per-module purpose and access matrix that engineering and QA should consult day-to-day.